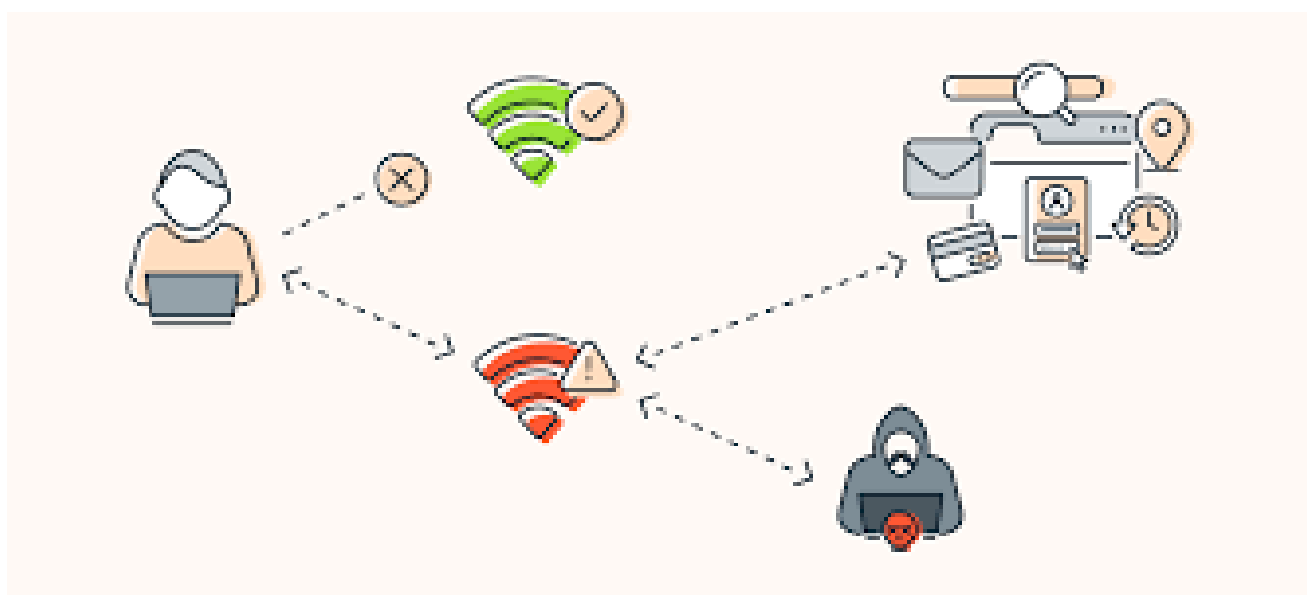


Ataque Evil Twin contra WPA2 Enterprise

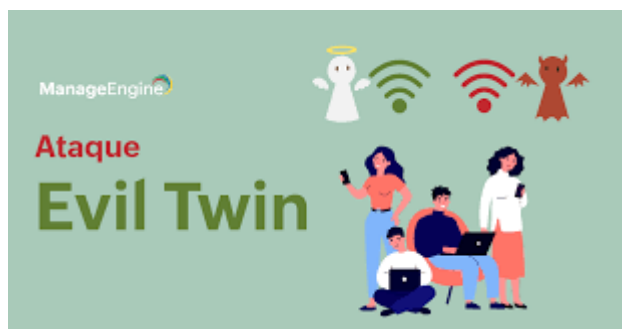


Contenido

¿Que es un ataque Evil Twin?	3
¿Qué es WPA2-Enterprise?	3
¿Cómo funciona el ataque Evil Twin?	3
Fases del ataque	4
1. Preparación de la infraestructura falsa	4
2. Enumeración de clientes	4
3. Deauthentication Attack	5
4. Captura de credenciales	5
¿Por qué funciona el ataque?	6
Riesgos del ataque	6
Medidas de mitigación	7
Validación estricta de certificados	7
Contraseñas fuertes	7
Monitorización inalámbrica	7
Bibliografía:	7

¿Que es un ataque Evil Twin?

El ataque Evil Twin (“gemelo malvado”) contra redes WPA2-Enterprise consiste en crear un punto de acceso falso que imita a la red Wi-Fi legítima de una empresa para engañar a los usuarios y capturar sus credenciales de autenticación. Según el artículo de [Infosec Institute](#), este ataque aprovecha principalmente errores de configuración y la falta de validación de certificados por parte de los clientes.



¿Qué es WPA2-Enterprise?

WPA2-Enterprise, también conocido como WPA-802.1X, está diseñado para entornos corporativos y utiliza autenticación centralizada mediante un servidor RADIUS. A diferencia de WPA2-PSK, donde todos usan una misma contraseña compartida, en WPA2-Enterprise cada usuario tiene credenciales individuales.

La arquitectura se basa en tres componentes:

- Supplicant: dispositivo cliente
- Authenticator: punto de acceso Wi-Fi
- Authentication Server: servidor RADIUS



¿Cómo funciona el ataque Evil Twin?

El ataque descrito por Infosec Institute se basa en realizar un Man-in-the-Middle (MitM) mediante un punto de acceso falso que suplanta a la red corporativa legítima. El atacante crea una infraestructura prácticamente idéntica a la original para conseguir que las víctimas se conecten automáticamente.

Fases del ataque

1. Preparación de la infraestructura falsa

El atacante necesita crear una infraestructura que imite a la red corporativa legítima. Para ello se configura:

- Un servidor RADIUS falso
- Un Access Point (AP) falso

El objetivo es que la víctima no detecte diferencias entre la red auténtica y la red maliciosa.

Para implementar esta infraestructura se utilizan herramientas como:

- FreeRADIUS-WPE
- Hostapd
- Aircrack-NG



2. Enumeración de clientes

Una vez desplegado el punto de acceso falso, el atacante realiza tareas de reconocimiento para identificar:

- puntos de acceso legítimos
- dispositivos conectados
- métodos de autenticación EAP utilizados

Esta fase se lleva a cabo mediante técnicas de sniffing inalámbrico y herramientas como airodump-ng, perteneciente a la suite Aircrack-NG.

El propósito es recopilar suficiente información para replicar de forma precisa la configuración de la red corporativa y aumentar la probabilidad de que los clientes se conecten al AP malicioso.

3. Deauthentication Attack

En esta fase, el atacante provoca la desconexión de los clientes de la red legítima enviando paquetes de desautenticación.

Cuando el dispositivo pierde conexión:

- Intenta reconectarse automáticamente
- Puede asociarse al AP falso si este presenta una señal más potente

El artículo utiliza la herramienta aireplay-ng --deauth para generar este tipo de paquetes.

Este ataque resulta especialmente efectivo en redes donde no está habilitada la protección de tramas de gestión (802.11w/PMF).

4. Captura de credenciales

Cuando el cliente se conecta al punto de acceso falso e intenta autenticarse:

- envía credenciales EAP
- se produce el intercambio challenge/response

En configuraciones basadas en PEAP o EAP-TTLS con MSCHAPv2, el atacante puede capturar hashes de autenticación.



¿Por qué funciona el ataque?

El artículo recalca que el problema principal NO es WPA2-Enterprise en sí, sino la mala configuración de los clientes.

El ataque tiene éxito cuando:

- el cliente no valida correctamente el certificado RADIUS
- el usuario acepta certificados desconocidos
- existen contraseñas débiles

La investigación académica “(In)Secure Configuration Practices of WPA2 Enterprise Supplicants” confirma que muchos dispositivos empresariales están configurados incorrectamente y son vulnerables al robo de credenciales mediante Evil Twin.



Riesgos del ataque

Un ataque exitoso puede permitir:

- robo de credenciales corporativas
- acceso a Active Directory
- movimiento lateral
- espionaje de tráfico
- acceso no autorizado a recursos internos



Medidas de mitigación

El artículo propone varias defensas:

Validación estricta de certificados

Los clientes deben:

- validar el certificado del servidor RADIUS
- confiar únicamente en la CA corporativa
- rechazar certificados desconocidos

Contraseñas fuertes

El artículo recomienda políticas robustas para evitar ataques de diccionario sobre MSCHAPv2.



Monitorización inalámbrica

Se recomienda:

- Usar sistemas WIDS/WIPS
- Detectar Rogue APs
- Monitorizar redes inalámbricas continuamente

Bibliografía:

<https://www.infosecinstitute.com/resources/hacking/attacking-wpa2-enterprise/>

https://myhackingnotes.com/wifi/wpa2_enterprise/

<https://hacktricks.wiki/en/generic-methodologies-and-resources/pentesting-wifi/evil-twin-eap-tls.html>